# TraceBack — Security and Threat Model Report

6 Nov 2026 · companion to the TraceBack Test Reports

**Overall risk: low for the code, moderate for operations. Every core control held under attack, under parallel requests and through failures: sign-in, roles, access to other students' data, and the claim rules. All 23 attacks were stopped and both library audits are clean. 5 risks remain open, all about accounts and the server rather than the code: setup secrets to rotate, SSH access, AWS and Gmail account protection, and database backups on laptops.** Each has a concrete fix (section 7), and each takes less than an hour.

TraceBack is the IIT Kanpur Lost & Found portal. Students report lost and found items, guards hold items at security offices, and owners claim them with an ID-card check.

## 1. Scope and method

- **System:** TraceBack as deployed on one AWS EC2 server (Sydney) at 16-176-186-149.sslip.io: website, API, worker, database, and the outside services it uses.
- **Method:** threats were listed per component with STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege). Each was checked against the code and configuration, and against the evidence from the adversarial tests (ADV-), concurrency tests (CON-) and test-report defects (DEF-). Likelihood and impact are rated Low, Medium or High.
- **Out of scope:** physical security at the offices, Google's and AWS's own infrastructure, and the security of each user's device.

## 2. What needs protecting

| Asset | Where it lives | Why it matters | Sensitivity |
|---|---|---|---|
| Secrets: `SECRET_KEY`, database password, Gmail app password, Groq and Gemini keys | `deploy/.env` on the server (readable only by its owner) | Anyone holding them can forge sign-ins, read the database or send email as the portal | Critical |
| Student identity data: name, roll number, phone, hall and room, email | `users` table | Needed for the ID check and for contacting owners | High |

| Asset | Where it lives | Why it matters | Sensitivity |
|---|---|---|---|
| ID-card photos and claim proof images | Photo volume on the server | Show faces, names and roll numbers | High |
| Sign-in codes and sessions | `login_codes`, `user_sessions` (stored only as HMAC hashes) | Control access to every account | High |
| Claim decisions and custody history | `claims`, `claim_events`, `custody_events` | Decide who gets an item; the audit trail | High |
| The physical items | Security offices | Valuables could go to the wrong person | High |
| Item reports and ordinary photos | `items`, `item_photos` | Public to signed-in students once held, by design | Medium |
| Availability of the portal | One t3.small server | Students and guards rely on it | Medium |

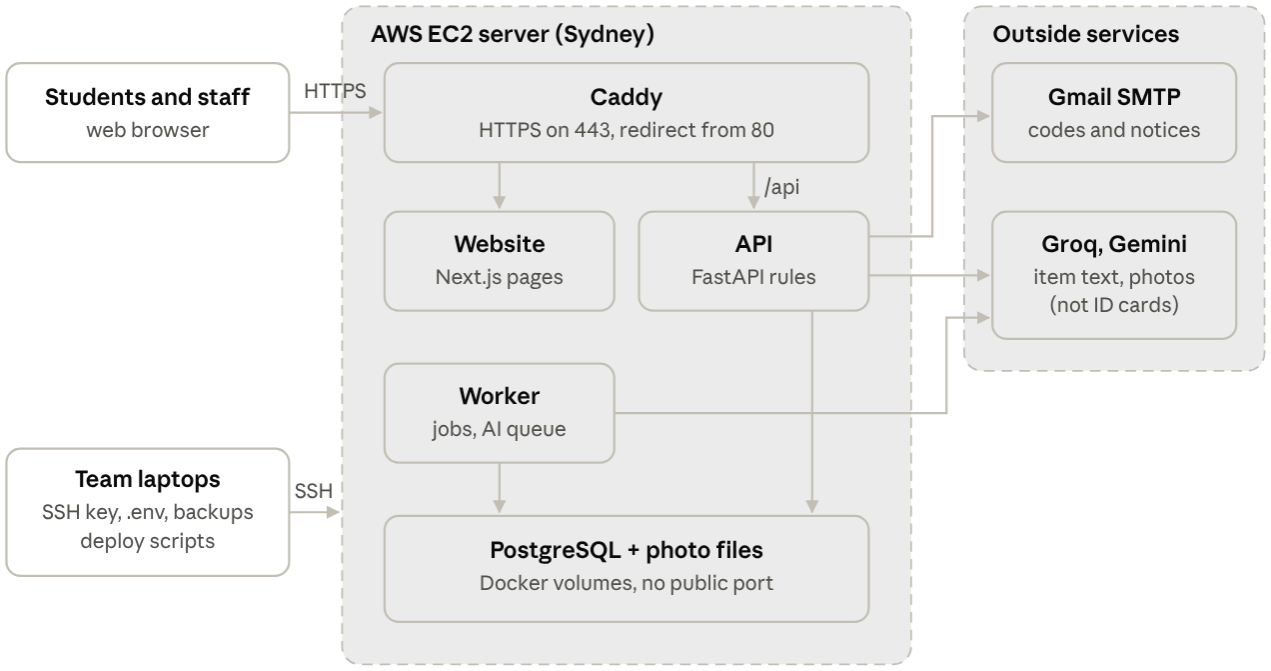
## 3. Who might attack

| Actor | Access | Likely goal |
|---|---|---|
| Dishonest or curious student | Signed in with an @iitk.ac.in account | Claim someone else's item, see others' data, become staff |
| Outsider on the internet | Can reach ports 80, 443 (and 22 if open) | Scan for weak spots, flood the site, harvest data |
| Careless or rogue guard or admin | Staff powers | Hand items to the wrong person, misuse personal data |
| Compromised outside service | Gmail account, AI provider, or a library | Read emails or data, run code through a vulnerable library |
| Someone with a team laptop or chat | `.pem` key, `.env` values, screenshots, backups | Take over the server or the accounts behind it |

# 4. System and trust boundaries

**Data crosses three trust boundaries: internet, server and outside services**

Dashed areas are trust boundaries; arrows show who sends data to whom




TraceBack as deployed on 3–6 Nov 2026 · from deploy/docker-compose.yml, deploy/Caddyfile and the backend code

- **Boundary 1, internet to server:** only Caddy is reachable, on HTTPS 443 (port 80 redirects). The database and the API have no public port.
- **Boundary 2, server to outside services:** emails leave over SMTP with TLS. Item text, plus photos outside the ID-card category, go to Groq and Gemini.
- **Boundary 3, admin access:** the team reaches the server over SSH with a key file and deploys with `upload.ps1`.

# 5. Threats by STRIDE category

| ID | STRIDE | Threat | Controls in place | Evidence | Residual risk |
|---|---|---|---|---|---|
| T-01 | Spoofing | Guessing a sign-in code | 6-digit random code, HMAC-hashed, 5 tries, 10 minutes, row locked while checked | ADV-01, ADV-23, CON-02, CON-03 | Low |

| ID | STRIDE | Threat | Controls in place | Evidence | Residual risk |
|---|---|---|---|---|---|
| T-02 | Spoofing | Stealing or forging a session | 256-bit token stored hashed; cookie HttpOnly, SameSite=Lax, Secure on HTTPS; logout deletes it | ADV-04, ADV-05 | Low |
| T-03 | Spoofing | Taking over a guard's or the portal's Gmail account | Staff Gmail accounts must be added by the admin first | Design review | Medium (low likelihood, high impact) |
| T-04 | Tampering | Changing another student's items or claims (IDOR) | Ownership and role checks on every endpoint | ADV-09: 9 of 9 refused | Low |
| T-05 | Tampering | Mass assignment: setting role, status or owner | Input schemas list only allowed fields | ADV-08, ADV-10 | Low |
| T-06 | Tampering | Race conditions in claim decisions and custody | Every claim and custody action locks the item, then the claim; unique index on approved claims; database constraints | CON-04 to CON-09: all pass, 40 of 40 trials | Low |
| T-07 | Tampering | SQL injection and stored XSS | ORM queries; search words reduced to letters and digits; React escapes text | ADV-12 to ADV-14 | Low |
| T-08 | Tampering | Malicious uploads (web shell, SVG, polyglot) | File type checked by its first bytes; random file names; 5 MB and 60-megapixel limits; served with nosniff | ADV-15, ADV-16 | Low |
| T-09 | Tampering | Vulnerable libraries (Next.js 16.4.0 and Pillow 12.3.0 were flagged) | Upgraded to Next.js 16.4.5 and Pillow 13.0.0; npm audit and pip-audit report nothing | ADV-24, ADV-25 (0 advisories on the final code) | Low |
| T-10 | Tampering | Prompt injection in an item description, steering the AI matcher | Agent may save only ids it was shown; weak matches never emailed; dates computed in code; staff review and ID check before any hand-over | Design review and the existing agent tests | Low |

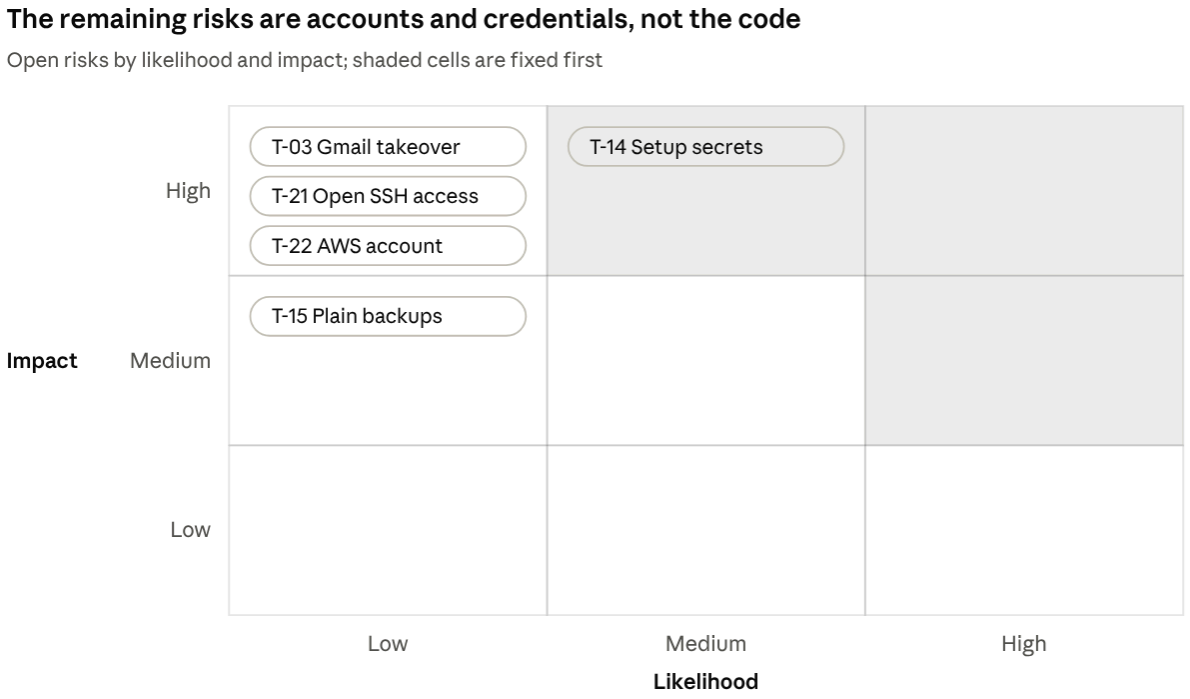
| ID | STRIDE | Threat | Controls in place | Evidence | Residual risk |
|---|---|---|---|---|---|
| T-11 | Repudiation | Staff denying a decision or hand-over | Every claim and custody step stores who and when; no endpoint deletes history | Integration tests; CON-08: no duplicate entries in races | Low |
| T-12 | Info disclosure | GPS location in photos shared with all students | EXIF, XMP and IPTC data removed from every photo and proof on upload; only the rotation flag is kept | ADV-17: no GPS data in the downloaded photo | Low |
| T-13 | Info disclosure | Personal data sent to Groq and Gemini (free-text descriptions, photos) | ID-card photos never sent; reporter details left out; photos flagged as personal discarded; the report form names the AI services used | Code review; AI integration tests | Low |
| T-14 | Info disclosure | Leaked secrets or API documentation | `.env` only on the server (mode 600) and git-ignored; API docs off in production. The Groq and Gemini keys, database password and `SECRET_KEY` were visible in screenshots taken during setup, so they are being rotated | ADV-21 (docs now 404); setup review | Medium (high impact) |
| T-15 | Info disclosure | Database backups with personal data on laptops | `backup*.sql` git-ignored | Setup review | Medium (low likelihood) |
| T-16 | Info disclosure | Missing security headers (clickjacking, sniffing) | HTTPS and HSTS by Caddy; nosniff, frame protection and Referrer-Policy on every page and API response; no X-Powered-By | ADV-16, ADV-19 (all headers present) | Low |

| ID | STRIDE | Threat | Controls in place | Evidence | Residual risk |
|---|---|---|---|---|---|
| T-17 | Denial of service | Small image that needs huge memory (decompression bomb) | 5 MB file limit; images over 60 megapixels refused before they are decoded | ADV-18: the 136 KB, 144-megapixel file is refused with 400 | Low |
| T-18 | Denial of service | Overload from many simultaneous users | At most 30 requests worked on at once, the rest wait in line; database pool sized to match; 2 API workers | CON-14; the load tests in the Performance report | Low |
| T-23 | Denial of service | Outage of the database, a crashed process, or an outside service (AI provider, mail server) going down | Docker restarts crashed containers; the database pool reconnects by itself; a clear 503 while the database is down; interrupted AI jobs run again; emails retried; AI matching falls back to rules | FR-01 to FR-10: all 10 recover | Low |
| T-19 | Denial of service | Flooding an inbox with sign-in codes | 60-second wait and 5 codes an hour, held under parallel requests by a lock per email address | CON-01, ADV-02 | Low |
| T-20 | Elevation of privilege | Student becoming staff or admin | Roles only set by an admin, or by `make-admin` on the server | ADV-06, ADV-07 | Low |
| T-21 | Elevation of privilege | Server takeover through SSH | Key-only login (AWS default). The SSH rule was opened to 0.0.0.0/0 during setup on 3 Nov | Setup review | Medium (high impact) |
| T-22 | Elevation of privilege | AWS account takeover | Free plan account; MFA status not checked | Setup review | Medium (high impact) |

**Strengths.** Sign-in, sessions, roles, ownership checks and claim rules held in every test, and they are enforced twice: in the API, and by database constraints. Claim and custody actions lock their database rows, so parallel requests cannot break the rules, and the API limits how many requests it works on at once. It also recovers on its own from a database outage, crashed processes and failing outside services (see the Failure and Recovery

report). Data is minimised: photo metadata is removed, proof images are deleted 2 days after a claim closes, returned items after 60 days, and the AI never sees names, emails or ID cards.

# 6. Risk matrix




5 open risks from section 5, all rated Medium · likelihood and impact are the team's judgement, based on the test evidence

The matrix places the 5 open risks. None is a flaw in the code: each concerns an account, a credential or a copy of the data. T-03, T-21 and T-22 are unlikely but serious, and cheap to fix, so they go in the first batch with T-14.

# 7. Recommendations

Already in this release: library upgrades (T-09), photo metadata removal (T-12), the AI-services notice on the report form (T-13), security headers and API docs off in production (T-14, T-16), row locks for claims and custody (T-06), the image pixel limit (T-17), the request limit (T-18) and the recovery fixes (T-23).

**Now, before the final demo**

1. Make new Groq and Gemini keys and a new Gmail app password, and set a new `SECRET_KEY` (this signs everyone out) (T-14).
2. Set the SSH rule back to **My IP**. Turn on MFA for the AWS account and 2-step verification for the portal's and the staff's Gmail accounts (T-03, T-21, T-22).

### Before wider campus use

3. Add a per-IP request-rate limit in Caddy for sign-in and uploads (T-19).
4. Run the containers as a non-root user. Keep backups encrypted, or only on the server (T-15).
5. Delete old sign-in codes, expired sessions and email logs regularly; today they are kept forever.

### Ongoing

6. Run `npm audit` and `pip-audit` before every deployment.
7. Rerun the adversarial and concurrency suites after any change to sign-in, claims or uploads.